

Reconnaissance and Information Gathering

1. Introduction to Penetration Testing

Penetration testing (often shortened to "pentesting") is a **simulated, authorized cyberattack** conducted against a computer system, network, web application, or organization to evaluate its security posture. Unlike malicious hackers, penetration testers operate under a legal agreement (a **Rules of Engagement / Scope of Work document**) that defines exactly what can be tested, when, and how.

1.1 Purpose of Penetration Testing

- Identify exploitable vulnerabilities before real attackers do
- Validate the effectiveness of existing security controls
- Test detection and response capabilities of the Blue Team/SOC
- Provide evidence-based risk prioritization to management
- Satisfy compliance requirements (PCI-DSS, ISO 27001, HIPAA, SOC 2, etc.)

1.2 Types of Penetration Testing

Type	Description
Black Box	Tester has zero prior knowledge of the target — simulates an external attacker starting from scratch
White Box	Tester has full knowledge (source code, network diagrams, credentials) — simulates an insider or thorough audit
Grey Box	Tester has partial knowledge — simulates a semi-informed attacker (e.g., a disgruntled employee or a partner with limited access)

1.3 The Standard Penetration Testing Methodology

Most professional frameworks (PTES, OSSTMM, NIST SP 800-115, OWASP Testing Guide) break a pentest into these phases:

1. **Pre-Engagement (Scoping & Agreement)**
2. **Reconnaissance / Information Gathering**
3. **Scanning & Enumeration**
4. **Vulnerability Analysis**
5. **Exploitation**
6. **Post-Exploitation**
7. **Reporting**

This document focuses heavily on **Phase 2 — Reconnaissance and Information Gathering**, which is arguably the most important phase because *everything that follows depends on the quality of the data collected here*.

2. The Pre-Engagement Step

Before any technical testing begins, a formal pre-engagement process must occur. Skipping this step is not just bad practice — it can expose the tester to **criminal liability** under laws such as the Computer Fraud and Abuse Act (CFAA) in the U.S., the Computer Misuse Act in the UK, or equivalent cybercrime laws elsewhere.

2.1 Key Deliverables of Pre-Engagement

- **Scope Definition** — Which IPs, domains, applications, or physical locations are in-scope? Which are explicitly out-of-scope?
- **Rules of Engagement (RoE)** — Testing windows, allowed techniques (e.g., is social engineering permitted? DoS testing?), emergency contacts
- **Authorization Letter / "Get Out of Jail Free" card** — Written, signed permission from the asset owner
- **Legal Agreements** — NDA (Non-Disclosure Agreement), MSA (Master Service Agreement), SOW (Statement of Work)
- **Communication Plan** — How and when will critical findings be reported during the test?
- **Goals & Success Criteria** — Is this a compliance-driven test, a red team exercise, or a targeted assessment of a new application?

Professional Note: A cybersecurity student should internalize this early — technical skill without proper authorization is not "penetration testing," it is a **crime**. Always operate within written scope.

3. What Is Information Gathering / Footprinting?

Footprinting (also called **reconnaissance** or **information gathering**) is the systematic process of collecting as much information as possible about a target organization, its systems, employees, and digital footprint *before* engaging in any active or intrusive testing.

The term "footprinting" comes from the idea of tracing the digital "footprints" an organization leaves behind — DNS records, employee social media posts, exposed services, metadata in documents, and more.

3.1 Why Footprinting Matters

- It is the **foundation** of every successful engagement — poor recon leads to missed attack surfaces

- It helps testers build a realistic **attack surface map**
- It reveals **human-layer weaknesses** (useful for social engineering assessments)
- It allows testers to identify **technology stacks**, which narrows down relevant vulnerabilities and exploits
- Real-world adversaries (APT groups, cybercriminals) spend a disproportionate amount of time on recon — often weeks or months — because it maximizes the success rate of later attack phases

3.2 Passive vs. Active Reconnaissance

This is one of the most important distinctions in this entire domain:

Aspect	Passive Reconnaissance	Active Reconnaissance
Definition	Gathering info without directly interacting with the target's systems	Gathering info by directly probing/interacting with target systems
Detectability	Virtually undetectable — target is unaware	Detectable — may trigger IDS/IPS, firewalls, logs
Examples	OSINT, WHOIS lookups, Google dorking, social media analysis, job postings	Port scanning, banner grabbing, ping sweeps, DNS zone transfers
Risk to Tester	Very low	Higher — could violate scope or alert defenders
Tools	Google, Shodan, theHarvester, Maltego, LinkedIn	Nmap, Netcat, hping3

Professional engagements typically **start with passive techniques** and only escalate to active techniques once explicitly authorized and scoped.

4. What Information Do We Gather?

A thorough footprinting phase aims to build a complete profile of the target across multiple categories:

4.1 Organizational Information

- Company name, subsidiaries, mergers/acquisitions
- Physical addresses, branch office locations
- Organizational structure and hierarchy
- Partner companies and third-party vendors (a common weak link — **supply chain attacks**)
- Press releases, financial reports, news articles

4.2 Network Information

- Domain names and subdomains
- IP address ranges (netblocks)
- DNS records (A, MX, NS, TXT, CNAME, SOA)
- Network topology hints (from traceroutes, DNS)
- Registered ASN (Autonomous System Number)

4.3 System Information

- Operating systems in use
- Web server software and versions (Apache, Nginx, IIS)
- Technology stack (CMS platforms like WordPress/Drupal, frameworks, programming languages)
- Open ports and running services (active phase)
- SSL/TLS certificate details (issuer, validity, Subject Alternative Names — often reveal internal hostnames)

4.4 Human / Employee Information

- Employee names, job titles, and roles (via LinkedIn)
- Email address naming conventions (e.g., firstname.lastname@company.com)
- Phone numbers and organizational charts
- Social media presence and behavioral patterns (useful for phishing pretext development)
- Leaked credentials from past breaches (checked via breach databases)

4.5 Document Metadata

- Author names embedded in PDFs, Word documents, and images
- Software versions used to create documents (reveals OS/software patch levels)
- Internal file paths, usernames, and printer/network share names left in metadata

5. Types of Information Gathering

Footprinting techniques are generally categorized as follows:

5.1 OSINT (Open Source Intelligence)

Collecting data from **publicly available sources** — the internet, social media, public records, news, and forums. OSINT is the backbone of passive reconnaissance and is legal because it uses information the target has voluntarily made public (or that is publicly indexed).

5.2 Network Footprinting

Identifying the target's network range, domain structure, and infrastructure — WHOIS data, DNS enumeration, and IP block identification (via ARIN, RIPE, APNIC regional registries).

5.3 DNS Footprinting

Extracting DNS records to reveal mail servers, name servers, subdomains, and sometimes internal infrastructure (especially if zone transfers are misconfigured and allowed).

5.4 Website Footprinting

Analyzing a target's website directly — technologies used, hidden comments in source code, robots.txt (which can reveal "disallowed" — often sensitive — directories), sitemap.xml, and archived historical versions via the **Wayback Machine**.

5.5 Email Footprinting

Determining email formats, mail server infrastructure (MX records), and sometimes tracking email headers to learn about internal mail routing and even geolocate a sender via IP in headers.

5.6 Social Engineering Footprinting

Gathering information directly or indirectly from humans — via phishing pretexting, phone calls (vishing), physical observation, or dumpster diving, primarily to support a later social engineering phase.

5.7 Competitive Intelligence

Understanding the target's market position, competitors, and business relationships — often gathered from financial filings (e.g., SEC EDGAR for public companies), press releases, and industry reports.

5.8 Google Hacking / Search Engine Footprinting

Using advanced search engine operators to uncover sensitive information indexed by search engines — covered in depth in Section 8.

6. How We Gather Information — Techniques and Tools

6.1 WHOIS Lookups

WHOIS databases store registration information for domain names, including registrant name, organization, email, and name servers (some of this may be redacted due to GDPR/privacy protection services).

```
whois example.com
```

6.2 DNS Enumeration

Tools like `dig`, `nslookup`, and `dnsrecon` extract DNS records:

```
dig example.com ANY
dig example.com MX
dig example.com NS
```

Attempting a **DNS zone transfer** (`dig axfr @nameserver example.com`) is a classic technique — if misconfigured, it dumps the entire DNS zone, revealing internal hostnames.

6.3 Subdomain Enumeration

Tools such as **Sublist3r**, **Amass**, and **crt.sh** (Certificate Transparency logs) discover subdomains that may host forgotten or less-protected applications (a very common source of real-world breaches).

6.4 OSINT Frameworks and Tools

- **theHarvester** — collects emails, subdomains, hosts, employee names from search engines and public sources
- **Maltego** — visual link-analysis tool that maps relationships between people, domains, IPs, and organizations
- **Shodan / Censys** — search engines for internet-connected devices; reveal exposed services, default credentials, and IoT devices
- **SpiderFoot** — automated OSINT reconnaissance tool that aggregates dozens of sources
- **Recon-ng** — a modular reconnaissance framework similar in feel to Metasploit

6.5 Social Media Intelligence

Platforms like LinkedIn, X (Twitter), Facebook, and Instagram often reveal job titles, technologies mentioned in job postings ("Looking for a DevOps engineer experienced in AWS and Jenkins" tells an attacker exactly what stack to target), and employee travel/location patterns.

6.6 Job Postings Analysis

Job listings are a goldmine — they frequently disclose internal software names, security tools in use ("experience with Splunk and CrowdStrike required"), and organizational structure.

6.7 The Wayback Machine

`archive.org`'s Wayback Machine stores historical snapshots of websites, which can reveal previously exposed pages, old admin panels, or removed sensitive content that may still be live on the server even though no longer linked.

6.8 Metadata Extraction

Tools like **ExifTool** or **FOCA** extract metadata from publicly available documents (PDF, DOCX, XLSX, images) to reveal usernames, software versions, internal paths, and even GPS coordinates from photos.

6.9 Email Header Analysis

Examining full email headers can reveal internal mail server hostnames, IP addresses, and the path an email took through internal infrastructure.

7. Reverse Image Search

7.1 What It Is

Reverse image search is an OSINT technique where, instead of searching *with* text, you search *with an image* to find where else that image appears online, or to identify a person, location, or object.

7.2 How It Works

Search engines index images using visual features (edges, colors, patterns) and metadata. When you upload or link an image, the engine compares it against its index to find visually similar or identical images.

7.3 Common Tools

- **Google Images / Google Lens**
- **TinEye** — specializes in finding the earliest known occurrence of an image online
- **Yandex Images** — often regarded by OSINT professionals as the most powerful for facial recognition and finding people
- **Bing Visual Search**

7.4 Use Cases in Penetration Testing / OSINT

- **Verifying identity** — confirming whether a profile picture used on a fake LinkedIn/social media account (used for social engineering) is a stolen photo of a real, unrelated person
- **Geolocation** — identifying the location where an employee's publicly posted photo was taken (background landmarks, signage) — useful for physical security assessments
- **Corporate asset identification** — finding leaked internal photos (whiteboards, badges, screens) that may appear on employee social media
- **Detecting fake or cloned company assets** — such as phishing pages using stolen company logos
- **Investigating fraudulent profiles** used in Business Email Compromise (BEC) or catfishing/pretexting scams

7.5 Ethical Consideration

Reverse image search touches on personal privacy. In a professional engagement, this technique is typically only used within the agreed scope (e.g., for a social engineering assessment specifically authorized by the client) and never for personal or unauthorized surveillance.

8. Google Hacking Database (GHDB)

8.1 What Is Google Hacking / Google Dorking?

Google Hacking (a.k.a. **Google Dorking**) is the practice of using **advanced search operators** to query search engines for very specific, often sensitive, information that has been unintentionally indexed — configuration files, login portals, exposed directories, database dumps, and more.

This works because Google's crawler indexes *everything* it can reach, including files and pages that administrators never intended to be publicly discoverable, but which weren't properly protected (e.g., no `robots.txt` disallow rule, no authentication).

8.2 The Google Hacking Database (GHDB)

The **GHDB** is a publicly maintained, categorized archive of effective Google dork queries, originally compiled by Johnny Long and now hosted by **Offensive Security** (the makers of Kali Linux and OSCP) at exploit-db.com/google-hacking-database.

Each entry in the GHDB is a real dork query mapped to a category of exposure it tends to reveal, such as:

- Login portals
- Files containing usernames/passwords
- Sensitive directories
- Vulnerable servers
- Files containing juicy information (backup files, config files)
- Error messages that disclose sensitive info
- Network or vulnerability data

8.3 Common Google Search Operators

Operator	Function	Example
site:	Restrict results to a specific domain	site:example.com
filetype:	Search for a specific file extension	filetype:pdf confidential
intitle:	Search for text in the page title	intitle:"index of"
inurl:	Search for text within the URL	inurl:admin login
intext:	Search for text within the page body	intext:"password"
ext:	Similar to filetype	ext:sql
cache:	View Google's cached version of a page	cache:example.com

Operator	Function	Example
- (minus)	Exclude a term	site:example.com -www
"..."	Exact phrase match	"internal use only"

8.4 Example Dork Queries and What They Reveal

`site:example.com filetype:pdf`

→ Finds all publicly indexed PDF files on the target domain (may include internal reports, resumes, invoices).

`intitle:"index of" "parent directory"`

→ Finds open directory listings — servers that expose their entire file structure due to misconfiguration.

`site:example.com inurl:login`

→ Locates login pages, useful for mapping the application's authentication surface.

`filetype:env "DB_PASSWORD"`

→ Searches for exposed `.env` configuration files that may contain database credentials (a genuinely common real-world finding).

`site:pastebin.com "example.com" password`

→ Searches paste sites for leaked credentials tied to the target domain.

Educational Note: These examples are shown purely to illustrate *how* the technique functions structurally. Running these queries against systems you do not own or have not been explicitly authorized to test is illegal in most jurisdictions, even though the query itself only touches a public search engine index.

8.5 Why the GHDB Matters for Pentesters

- It provides a **ready-made checklist** of known-effective dork patterns, saving reconnaissance time
- It helps testers understand what an **unsophisticated attacker** could find with zero technical exploitation skill — often the most damning finding in a report
- It reinforces to organizations *why* proper access controls, `robots.txt` configuration, and removing sensitive files from web roots matter

8.6 Defensive Takeaways (Blue Team Perspective)

As a cybersecurity student, you should understand this technique from both sides:

- **Never store sensitive files** (backups, configs, credentials) inside publicly accessible web directories
 - Use `robots.txt` correctly, but understand it is **not a security control** — it's a request, not an enforcement mechanism, and dork queries can still find disallowed content if it's linked or indexed elsewhere
 - Regularly **self-audit** your organization's exposure using the GHDB and tools like Google Search Console
 - Implement proper `.htaccess` / server-level access restrictions on sensitive file types
-

9. Putting It All Together — The Recon Workflow

A professional footprinting workflow typically follows this logical order:

1. **Define scope** (from pre-engagement) — which domains, IP ranges, and entities are in bounds
 2. **Passive OSINT sweep** — WHOIS, DNS records, subdomain enumeration, Shodan/Censys, social media, job postings
 3. **Website & document analysis** — source code review, metadata extraction, Wayback Machine review
 4. **Google dorking / GHDB queries** — targeted search engine exposure discovery
 5. **Reverse image search** — verify identities, geolocate assets, detect impersonation
 6. **Consolidate findings** — build an attack surface map: domains, subdomains, IPs, technologies, employee list, email format, exposed files
 7. **Hand off to Scanning & Enumeration phase** — the active technical phase now begins, informed entirely by what was discovered here
-

10. Key Takeaways for Students

- Reconnaissance is not a "throwaway" phase — it is the **most time-intensive and highest-leverage phase** of a real engagement
- Always distinguish **passive vs. active** techniques and understand the legal/detection implications of each
- OSINT skill is built through **practice and curiosity** — learn to think like an investigator, not just a technician
- Every tool mentioned here (theHarvester, Maltego, Shodan, Recon-ng, GHDB) should be practiced **only in authorized lab environments** (e.g., TryHackMe, HackTheBox, your own test infrastructure, or explicitly authorized bug bounty programs)
- Document everything — professional recon reports are detailed and reproducible, not just a mental list of findings